

---

## Sécurité et administration

---

### Proposition XANADU

---

Vendredi 19 décembre 2025

# TABLE DES MATIÈRES

---

|                                                    |           |
|----------------------------------------------------|-----------|
| <b>Introduction</b>                                | <b>2</b>  |
| Présentation du projet . . . . .                   | 2         |
| Contexte et enjeux . . . . .                       | 2         |
| Objectifs de la mission . . . . .                  | 2         |
| <b>Présentation globale de l'architecture</b>      | <b>3</b>  |
| Topologie globale . . . . .                        | 3         |
| Description de l'infrastructure physique . . . . . | 4         |
| <b>Architecture et Segmentation</b>                | <b>6</b>  |
| Sécurité par isolation . . . . .                   | 7         |
| Optimisation . . . . .                             | 10        |
| L'adressage . . . . .                              | 10        |
| <b>Interconnexion et Mobilité</b>                  | <b>12</b> |
| VPN Site-à-Site . . . . .                          | 12        |
| VPN Client . . . . .                               | 13        |
| <b>Haute Disponibilité et Services Critiques</b>   | <b>14</b> |
| Redondance du DC . . . . .                         | 14        |
| RODC à Springfield . . . . .                       | 16        |
| Supervision . . . . .                              | 17        |
| <b>Sécurité Avancée</b>                            | <b>19</b> |
| DMZ (Zone Démilitarisée) . . . . .                 | 19        |
| Sauvegarde . . . . .                               | 22        |
| Air Gap (Zone Hors ligne) . . . . .                | 24        |
| <b>Surcoûts entraînés</b>                          | <b>25</b> |
| <b>Conclusion</b>                                  | <b>28</b> |

# INTRODUCTION

---

## PRÉSENTATION DU PROJET

---

Le présent rapport expose la stratégie de modernisation et de sécurisation du Système d'Information (SI) de l'entreprise XANADU. À l'occasion de son déménagement vers la technopole Atlantis et de l'ouverture d'un nouveau bureau à Springfield, XANADU souhaite transformer son infrastructure actuelle pour la rendre plus robuste.

## CONTEXTE ET ENJEUX

---

Actuellement, l'entreprise fait face à des défis majeurs :

- **Sécurité accrue** : Suite aux récentes cyberattaques par rançongiciel (ransomware) subies par des partenaires, la direction exige un système capable de résister aux menaces et de garantir la protection des données.
- **Continuité d'activité** : L'objectif est de garantir une reprise de service sous 4 heures pour les outils critiques (comme l'ERP) et 24 heures pour les autres services.
- **Centralisation des données** : Le passage d'une gestion locale (clés USB, dossiers sur PC) à une gestion centralisée est nécessaire pour assurer la cohérence et la sauvegarde des documents de travail.

## OBJECTIFS DE LA MISSION

---

La mission confiée à notre équipe CESITECH se décline en trois axes principaux :

- **Fiabilité** : Interconnecter de manière stable les sites d'Atlantis et de Springfield via un tunnel sécurisé.
- **Accessibilité** : Permettre le télétravail et l'accès distant pour les commerciaux en toute sécurité.
- **Confidentialité** : Mettre en place une gestion stricte des droits d'accès pour que chaque service (RH, Juridique, Commercial, etc.) ne voie que ce qui le concerne.

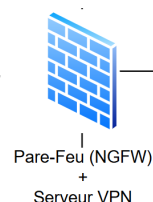


## DESCRIPTION DE L'INFRASTRUCTURE PHYSIQUE

---

### Les Pare-feu (NGFW – Next Generation Firewall)

Les pare-feu constituent le premier niveau de défense du système d'information. Positionnés à l'entrée de chaque site, ils assurent la protection périmétrique et le contrôle des échanges entre les différentes zones du réseau.



- **Rôle** : Filtrage des flux entrants et sortants afin de bloquer les accès non autorisés et les comportements suspects.
- **Fonctions avancées** : Inspection applicative, journalisation des connexions et application de politiques de sécurité différenciées.
- **VPN** : Mise en place et gestion du tunnel VPN site-à-site sécurisé entre Atlantis et Springfield.

### Les Routeurs

Les routeurs assurent l'acheminement du trafic entre les différents réseaux et garantissent la communication entre le LAN interne et les réseaux externes.



- **Rôle** : Routage des paquets entre les réseaux internes, la DMZ et le WAN.
- **Fonction réseau** : Séparation logique des flux et support de l'architecture multi-sites.

### Les Switchs (Commutateurs)

Les switchs assurent la connectivité interne et la segmentation logique du réseau local.



- **Rôle** : Connexion physique des postes de travail, serveurs et périphériques.
- **Segmentation** : Gestion des VLANs permettant de séparer les services (Comptabilité, RH, Direction, etc.).
- **Sécurité** : Réduction des domaines de diffusion et limitation de la propagation des incidents réseau.

## Les Serveurs

Les serveurs constituent le cœur du système d'information de XANADU. Ils hébergent les services critiques indispensables au fonctionnement de l'entreprise et à la continuité de l'activité.



- **Services hébergés** : Contrôleurs de domaine Active Directory (authentification, gestion des droits et GPO), ERP, services DNS, DHCP, supervision et sauvegarde.
- **Virtualisation** : Optimisation des ressources matérielles, flexibilité opérationnelle et restauration rapide en cas d'incident.
- **Disponibilité** : Redondance des services critiques afin d'éliminer les points de défaillance uniques.
- **Sécurité** : Intégration dans une architecture segmentée avec filtrage strict des accès.

## Les Périphériques (Imprimantes et Copieurs)

Les périphériques représentent des équipements sensibles pouvant constituer des points d'entrée en cas de mauvaise configuration.



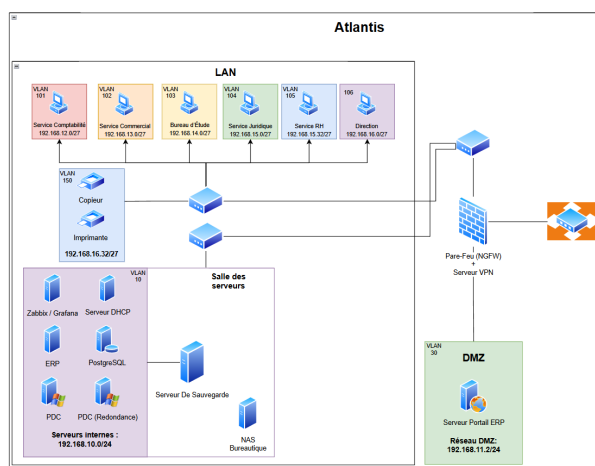
- **Rôle** : Fournir des services d'impression et de numérisation aux utilisateurs.
- **Sécurité** : Isolation dans un VLAN dédié (VLAN 150) afin d'éviter qu'une compromission ne puisse impacter les serveurs ou le réseau interne.

# ARCHITECTURE ET SEGMENTATION

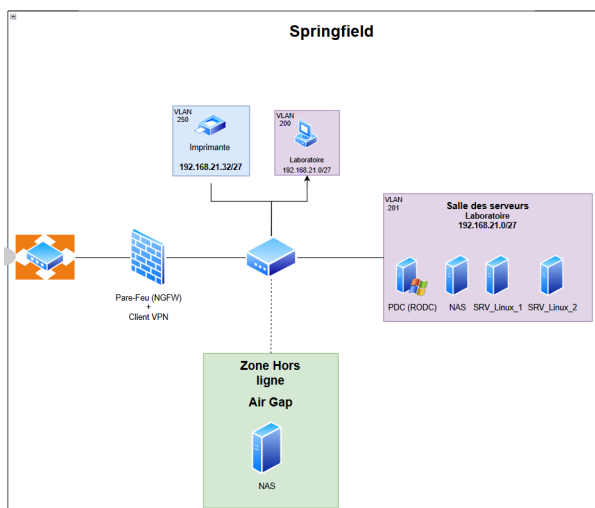
L'architecture réseau de XANADU repose sur une segmentation logique stricte, combinée à une séparation physique et fonctionnelle des sites. Cette approche vise à garantir un haut niveau de sécurité, de performance et de résilience, tout en assurant la conformité aux bonnes pratiques de l'ANSSI en matière de cloisonnement des zones de confiance.

L'infrastructure est organisée autour de deux sites distincts :

- le site principal **Atlantis**, hébergeant les services critiques et le cœur du système d'information ;



- le site distant **Springfield**, dédié aux activités de laboratoire et disposant d'une autonomie partielle.

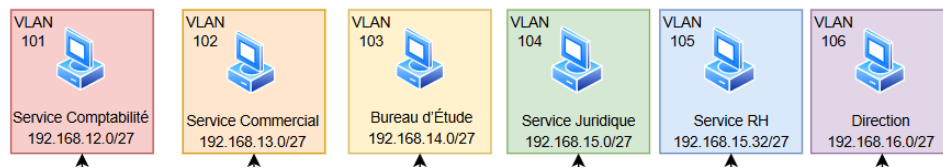


Ces deux sites sont interconnectés de manière sécurisée via un tunnel VPN site-à-site, assurant la confidentialité, l'intégrité et l'authentification des flux inter-sites.

## SÉCURITÉ PAR ISOLATION

La sécurité de l'architecture repose en grande partie sur une stratégie d'isolation stricte des ressources, basée sur le principe de défense en profondeur. Chaque zone fonctionnelle est isolée dans un VLAN dédié, constituant une zone de confiance distincte avec des règles de filtrage spécifiques.

Sur le site d'Atlantis, le réseau interne est segmenté par service métier :



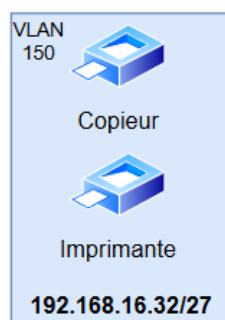
- VLAN Service Comptabilité
- VLAN Service Commercial
- VLAN Bureau d'Études
- VLAN Service Juridique
- VLAN Ressources Humaines
- VLAN Direction

Cette segmentation permet de limiter les déplacements latéraux en cas de compromission d'un poste utilisateur. Un incident affectant un service ne peut ainsi pas se propager librement aux autres services ou aux serveurs critiques.

### Les Périphériques (Imprimantes et Copieurs)

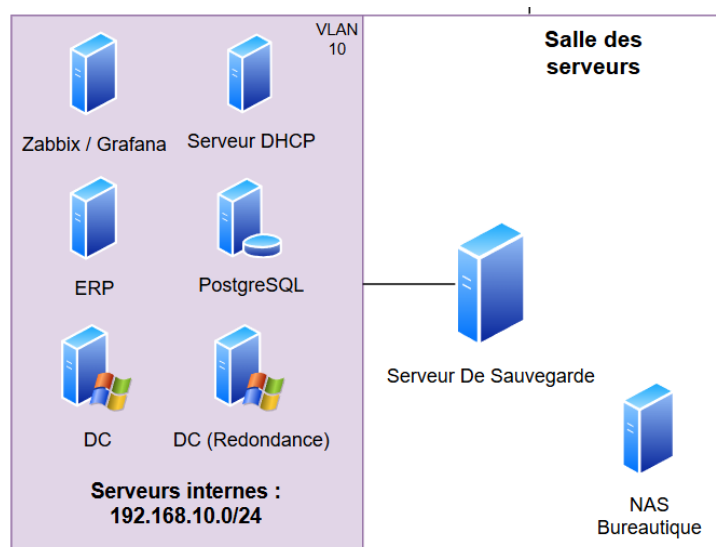
Les équipements partagés tels que les imprimantes et copieurs sont placés dans des VLAN dédiés, évitant tout accès direct depuis les postes utilisateurs aux équipements d'infrastructure. Cette isolation réduit considérablement les risques liés aux attaques exploitant des périphériques souvent moins sécurisés.

- **Rôle** : Fournir des services d'impression et de numérisation aux utilisateurs.
- **Sécurité** : Isolation dans un VLAN dédié (VLAN 150) afin d'éviter qu'une compromission ne puisse impacter les serveurs ou le réseau interne.





Les serveurs internes (ADDS, DNS, DHCP, ERP, PostgreSQL, supervision, sauvegarde) sont regroupés dans un réseau serveurs dédié.



Cette zone est considérée comme hautement sensible et n'est accessible que depuis des flux strictement contrôlés, principalement à des fins d'administration ou de fonctionnement applicatif.

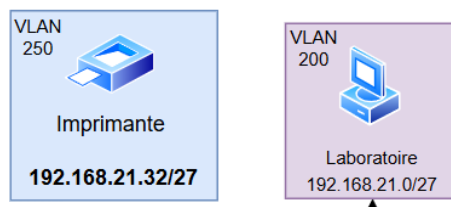
La **DMZ**, implémentée via un VLAN spécifique, héberge exclusivement le serveur Portail ERP exposé vers Internet.



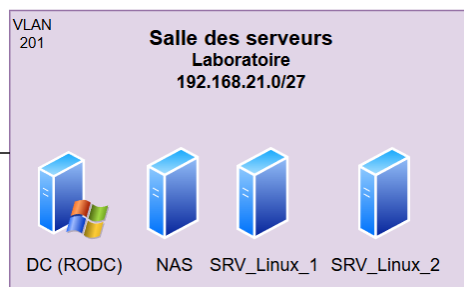
Cette zone constitue une barrière de sécurité essentielle entre le réseau externe non fiable et le LAN interne. Aucune communication directe entre Internet et le LAN n'est autorisée ; tous les flux transitent par le pare-feu **NGFW**, qui applique des règles de filtrage restrictives.

Sur le site de Springfield, l'isolation est également appliquée :

- un VLAN Laboratoire pour les machines de test et de développement ;
- un VLAN dédié aux imprimantes ;



- une salle serveurs distincte hébergeant un RODC, des serveurs Linux et un NAS local.



La présence d'un **RODC (Read Only Domain Controller)** renforce la sécurité du site distant en empêchant toute modification de l'Active Directory depuis ce site, tout en permettant l'authentification locale en cas de coupure du lien WAN.

Enfin, une **zone hors ligne Air Gap** est physiquement isolée du réseau.



Elle constitue une dernière ligne de défense contre les attaques avancées, notamment les ransomwares, en garantissant l'existence d'une sauvegarde inaccessible depuis le réseau.

## OPTIMISATION

---

La **segmentation** mise en place contribue également à l'optimisation globale du système d'information, tant sur le plan des performances que de l'exploitation.

La séparation des flux par VLAN permet :

- de réduire les domaines de broadcast et donc la charge réseau ;
- d'améliorer la qualité de service pour les applications critiques (ERP, AD, DNS) ;
- de faciliter la mise en place de règles de priorisation et de contrôle des flux.

Les **flux inter-VLAN** sont centralisés et contrôlés au niveau du pare-feu NGFW, ce qui offre une visibilité complète sur les communications internes et externes. Cette centralisation simplifie également l'analyse des incidents et la supervision de la sécurité.

L'utilisation d'un **tunnel VPN site-à-site** permet d'optimiser les échanges entre Atlantis et Springfield en assurant une interconnexion transparente et sécurisée. Les utilisateurs du site distant accèdent aux ressources du site principal comme s'ils étaient sur le même réseau logique, sans exposer les services internes à Internet.

La présence d'un **proxy Zabbix** à Springfield limite les échanges de supervision sur le lien WAN. Les données sont collectées localement puis synchronisées avec le serveur central, réduisant ainsi la consommation de bande passante et garantissant la continuité de la supervision même en cas de coupure temporaire.

L'**architecture virtualisée** des serveurs critiques (ERP, AD, supervision, sauvegarde) permet une meilleure utilisation des ressources matérielles, une plus grande flexibilité lors des opérations de maintenance et une reprise plus rapide en cas d'incident, en cohérence avec les objectifs de PCA et PRA.

## L'ADRESSAGE

---

Le plan **d'adressage IP** a été conçu de manière hiérarchique, lisible et évolutive, afin de faciliter l'administration, le dépannage et l'extension future de l'infrastructure.

Chaque VLAN est associé à un sous-réseau distinct en /27 pour les réseaux utilisateurs, garantissant un nombre d'adresses suffisant tout en limitant la surface d'attaque et les diffusions inutiles. Les réseaux serveurs utilisent des plages plus larges lorsque nécessaire, comme le réseau interne principal en /24.

Sur le site d'Atlantis :

- les VLAN métiers disposent chacun de leur propre sous-réseau ;
- le réseau serveurs internes est regroupé sur un sous-réseau dédié ;
- la DMZ utilise un sous-réseau distinct (192.168.11.0/24), clairement identifié comme zone exposée.

Sur le site de Springfield :

- le VLAN Laboratoire et le VLAN Imprimantes sont séparés ;
- la salle serveurs dispose de son propre sous-réseau ;
- la zone Air Gap ne dispose pas d'adressage routable permanent.

Ce découpage permet :

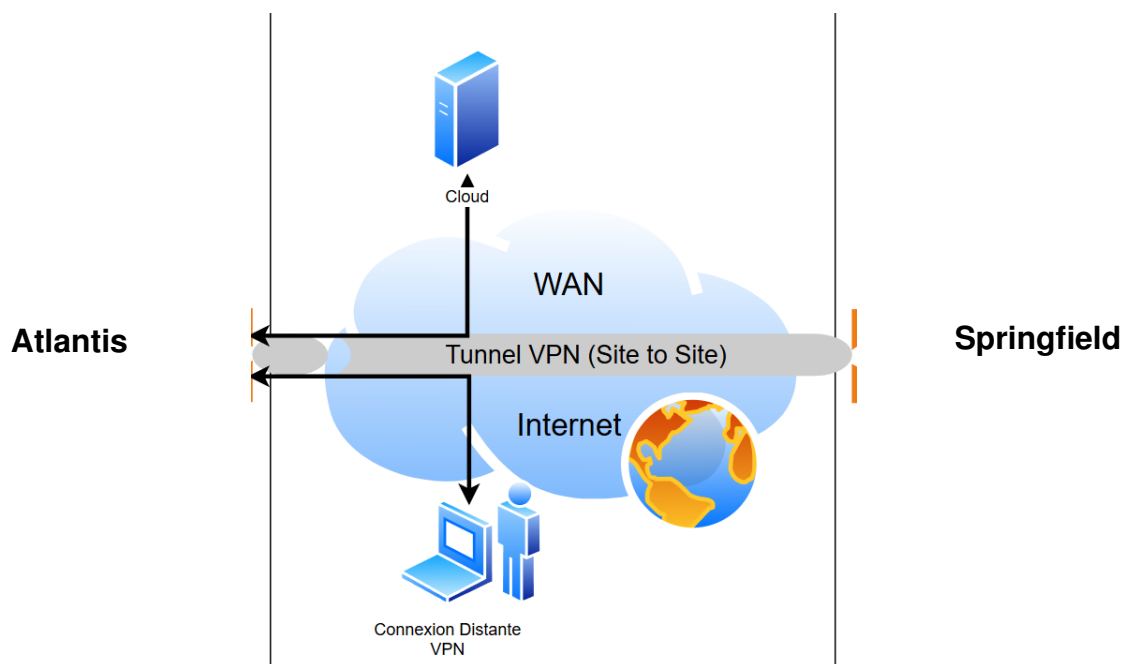
- une identification immédiate de l'origine d'un flux réseau ;
- une application précise des règles de filtrage et de sécurité ;
- une évolutivité maîtrisée en cas d'ajout de nouveaux services ou sites.

L'ensemble du plan d'adressage s'inscrit dans une logique de cohérence globale, facilitant la supervision, la journalisation et les audits de sécurité, tout en renforçant la maîtrise opérationnelle du système d'information de XANADU.

# INTERCONNEXION ET MOBILITÉ

## VPN SITE-À-SITE

Afin d'assurer une communication sécurisée et continue entre les sites **Atlantis** et **Springfield**, une architecture VPN a été mise en place.



Le VPN *site-to-site* permet de relier de manière permanente les réseaux locaux des deux sites à travers Internet de façon chiffrée.

Ce choix garantit :

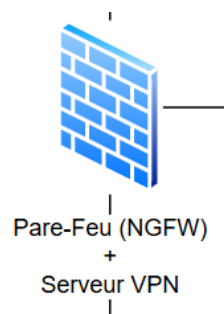
- **Une interconnexion sécurisée** entre les infrastructures distantes : le tunnel chiffré protège les flux de données contre toute interception extérieure.
- **L'accès aux ressources internes** (serveurs, partages, sauvegardes) comme si les sites étaient sur un même réseau local, facilitant le travail collaboratif entre les deux entités.
- **La continuité d'activité** en cas de besoin d'accès aux données hébergées sur l'autre site, assurant une haute disponibilité du Système d'Information (SI).
- **Le support du PCA/PRA**, notamment pour les restaurations et les échanges de sauvegardes, permettant de respecter les objectifs de *Recovery Time Objective* (RTO) et *Recovery Point Objective* (RPO).

Ce VPN est essentiel pour la réplication, la gestion centralisée et la cohérence du système d'information. Il assure une interconnexion permanente et transparente, indispensable à la survie de l'activité en cas de sinistre sur l'un des sites.

## VPN CLIENT

---

Le VPN *client-to-site* permet aux utilisateurs ou administrateurs autorisés de se connecter à distance au réseau interne de manière sécurisée.



Ce mécanisme complète l'architecture réseau en offrant une flexibilité essentielle.

Il est utilisé pour :

- **Le télétravail sécurisé** : les collaborateurs accèdent à leurs outils habituels via une connexion authentifiée et protégée.
- **Les interventions d'administration à distance** : les techniciens peuvent maintenir les serveurs critiques (ERP, ADDS) sans être physiquement sur place.
- **L'accès aux ressources internes sans exposition directe sur Internet** : cela réduit la surface d'attaque en évitant d'ouvrir des ports sensibles sur le web.

Ce mécanisme renforce la sécurité tout en conservant de la flexibilité opérationnelle, garantissant ainsi que la mobilité des utilisateurs ne compromette pas l'intégrité du réseau de l'entreprise.

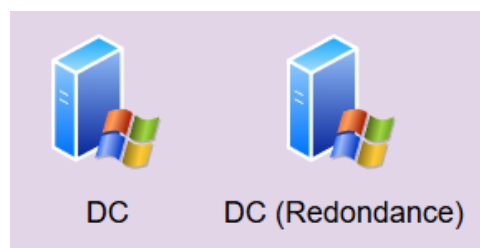
# HAUTE DISPONIBILITÉ ET SERVICES CRITIQUES

---

## REDONDANCE DU CONTRÔLEUR DE DOMAINE (DC)

---

La mise en place d'une redondance des contrôleurs de domaine (Domain Controllers – DC) sur le site principal d'Atlantis constitue un élément fondamental de la stratégie de haute disponibilité et de sécurité du système d'information de XANADU. Cette redondance permet de prévenir et résoudre les problèmes matériels et d'assurer une disponibilité maximale du SI.



**L'Active Directory (AD)** représente le cœur du système d'information, assurant notamment :

- l'authentification et l'autorisation des utilisateurs,
- la gestion des droits d'accès aux ressources,
- l'application des stratégies de sécurité (GPO),
- l'accès aux services essentiels (ERP, VPN, fichiers, messagerie).

La compromission ou l'indisponibilité d'un DC peut paralyser totalement le système d'information. La redondance ne constitue donc pas seulement un mécanisme de disponibilité, mais également une mesure de sécurité active.

### Continuité de l'authentification

Sans redondance, une panne matérielle, une saturation ou une maintenance du DC principal peut entraîner :

- l'impossibilité pour les utilisateurs de se connecter,
- l'échec de l'application des GPO,
- le blocage de l'accès aux services critiques,
- une perte de capacité d'action des équipes IT en situation de crise.

La redondance permet aux postes et serveurs de disposer de plusieurs DC disponibles.

Même en cas de dégradation, d'isolement temporaire ou de maintenance, l'authentification reste fonctionnelle, garantissant la continuité de l'activité et la capacité de répondre aux incidents de sécurité.

### **Résilience face aux attaques ciblant l'Active Directory**

Les DC sont des cibles privilégiées pour les attaquants via :

- les attaques sur Kerberos,
- l'exploitation du DNS intégré à l'AD,
- des attaques par déni de service (DoS),
- des ransomwares ou corruptions logiques.

La redondance répartit la charge et les rôles, rendant une attaque isolée inefficace et augmentant la difficulté pour un attaquant de neutraliser l'ensemble du SI.

### **Sécurisation des mises à jour et des évolutions AD**

Les mises à jour du système ou de l'AD, ainsi que les modifications de GPO ou du schéma AD, peuvent introduire des risques. La redondance permet :

- une application progressive des mises à jour,
- des tests et validations avant généralisation,
- une isolation rapide d'un DC défaillant,
- une restauration ciblée sans interruption globale du service.

### **Protection contre la corruption logique de l'AD**

Les ransomwares ou scripts malveillants peuvent altérer les GPO, désactiver ou créer des comptes. La redondance permet de détecter les incohérences, restaurer l'état de l'AD et améliorer le rollback grâce aux sauvegardes.

### **Sécurisation du service DNS**

Le DNS intégré à l'AD est critique pour la résolution des flux internes. La redondance assure une résolution DNS redondante, augmentant la tolérance aux pannes et limitant l'impact des attaques par saturation ou empoisonnement.

### **Réduction du risque humain**

Les erreurs d'administration sont une cause majeure d'incidents. La redondance permet de restaurer un DC sans interrompre la disponibilité globale, assurant la continuité opérationnelle.



## Respect des contraintes métiers

Cette architecture permet de respecter les exigences de XANADU :

- un RTO de 4 heures pour les services critiques,
- l'absence de point de défaillance unique,
- une meilleure résilience face aux attaques,
- une journalisation continue même en cas d'incident.

## RODC SUR LE SITE DE SPRINGFIELD

---

Le site distant de Springfield héberge un laboratoire, avec des machines Linux, et dépend d'un lien MPLS.



La mise en place d'un **RODC (Read Only Domain Controller)** offre plusieurs avantages :

- sécurité renforcée, car les mots de passe sensibles ne sont pas stockés localement,
- confinement des attaques à l'échelle locale, sans possibilité de modifier l'AD,
- continuité de l'activité, les utilisateurs pouvant s'authentifier localement en cas de coupure du MPLS,
- amélioration des performances grâce à l'authentification locale réduisant la latence et les échanges réseau.

Le RODC offre donc une solution comprenant de la disponibilité et de la sécurité pour le site distant de Springfield tout en protégeant le système d'information de XANADU et en permettant un maintien de l'activité du laboratoire même en cas de coupure du lien MPLS entre les deux sites.

## SUPERVISION

---

La supervision informatique englobe l'ensemble des outils, techniques et processus permettant de surveiller en continu le matériel, les logiciels et le réseau.



### Outils de supervision

La solution pour XANADU repose sur :

- **Zabbix** : serveur central, proxy pour sites distants, agents sur serveurs Windows/Linux, collecte et analyse des métriques,
- **SNMP** : supervision des équipements réseau et état du matériel,
- **ICMP** : vérification de la disponibilité et de la latence des liens réseau,
- **Scripts personnalisés** : surveillance spécifique (sauvegardes, ERP, détection de ransomware),
- **Grafana (optionnel)** : visualisation des tableaux de bord et tendances historiques.

### Méthodologie de collecte

Les agents Zabbix installés sur les serveurs Windows (AD, DNS, DHCP) et Linux (ERP, laboratoire) collectent CPU, RAM, stockage, services actifs et logs critiques. Les scripts personnalisés assurent la supervision des sauvegardes et la détection des comportements anormaux.

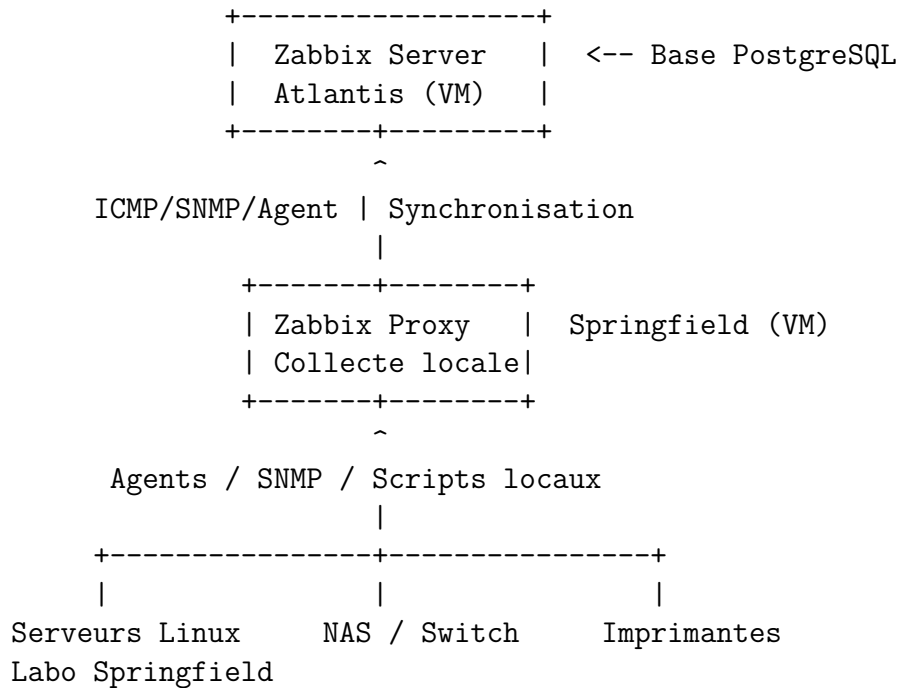
La collecte s'effectue en mode :

- actif pour les tests ICMP et certaines métriques,
- passif pour la majorité des agents, interrogés à la demande par le serveur central.

### Architecture de supervision

L'architecture comprend :

- un serveur Zabbix sur VM à Atlantis avec base PostgreSQL,
- un proxy Zabbix à Springfield pour collecter localement les données et synchroniser lors de la restauration du lien MPLS,
- des agents Zabbix sur tous les serveurs critiques, NAS et équipements réseau.



## Seuils et alertes

Des seuils critiques sont définis pour chaque élément supervisé, déclenchant :

- alertes d'avertissement : email à l'équipe IT et aux administrateurs,
- alertes critiques : email et message Teams avec escalade temporelle (0–30 min : équipe interne, 30–120 min : CESITECH),
- journalisation complète pour audit et traçabilité.

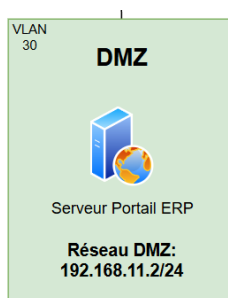
## Conclusion

L'architecture de supervision repose sur un serveur central et un proxy distant, utilisant agents, SNMP, ICMP et scripts personnalisés. Elle permet une détection proactive des incidents, une haute disponibilité des services critiques, un respect des SLA et RTO/RPO, tout en restant extensible pour de nouveaux sites ou équipements. Le serveur et le proxy (avec PostgreSQL) peuvent être déployés dans des containers Docker pour plus de résilience et flexibilité.

## DMZ (ZONE DÉMILITARISÉE)

---

Dans le cadre de ce projet, la mise en place d'une **zone démilitarisée (DMZ – Demilitarized Zone)** répond à un objectif fondamental de sécurisation de l'architecture réseau. Une DMZ est une zone intermédiaire située entre un réseau externe, tel qu'Internet, considéré comme non fiable, et le réseau interne de l'entreprise, qui héberge les ressources critiques du système d'information.



Le rôle principal de la DMZ est de permettre l'exposition contrôlée de services accessibles depuis l'extérieur, tout en évitant une exposition directe du réseau interne. Elle agit ainsi comme une zone tampon, limitant les risques d'intrusion et de propagation d'attaques vers les infrastructures sensibles.

Dans l'architecture retenue, la DMZ a été spécifiquement conçue pour héberger le serveur **Portail ERP**, un service applicatif nécessitant un accès distant pour les utilisateurs externes. Ce positionnement permet de concilier accessibilité du service, performance et exigences de sécurité, en isolant ce serveur du réseau interne.

### Enjeux de sécurité et séparation des zones de confiance

L'un des principaux enjeux de cette architecture est la protection du réseau interne face aux risques induits par l'exposition de services sur Internet. Tout service accessible depuis l'extérieur constitue un point d'entrée potentiel pour des attaques telles que :

- les scans de ports,
- l'exploitation de vulnérabilités applicatives,
- les attaques automatisées ou par force brute,
- les tentatives d'intrusion ciblées.

Placer le serveur Portail ERP directement au sein du réseau local interne (LAN) aurait exposé l'ensemble du système d'information à ces menaces. Une compromission de ce serveur aurait alors pu entraîner un accès direct aux ressources internes, augmentant considérablement l'impact de l'attaque.

La mise en place d'une DMZ permet au contraire de cloisonner ce service dans une zone de confiance intermédiaire. En cas de compromission du serveur ERP, l'attaquant resterait confiné à la DMZ et ne pourrait accéder au réseau interne qu'au travers de règles de sécurité strictement contrôlées par le pare-feu. Ce principe de cloisonnement constitue une mesure essentielle de défense en profondeur.

### Rôle du pare-feu pfSense dans la sécurisation de la DMZ

Le pare-feu **pfSense** joue un rôle central dans la sécurisation de l'architecture réseau. Il constitue le point de contrôle unique entre les différentes zones de sécurité :

- Internet,
- la DMZ,
- le réseau interne (LAN).

pfSense assure la segmentation logique du réseau, le filtrage des flux entrants et sortants, ainsi que la gestion fine des règles d'accès entre les zones. Chaque zone bénéficie de politiques de sécurité distinctes, adaptées à son niveau de confiance.

Le pare-feu permet également la journalisation détaillée des connexions, offrant une visibilité complète sur les flux transitant par la DMZ. Cette fonctionnalité facilite la supervision, l'analyse des événements de sécurité et la détection d'activités suspectes ou anormales.

### Mise en œuvre technique et segmentation réseau

Sur le plan technique, la DMZ est implémentée à l'aide d'un **VLAN dédié**, le **VLAN 30**, associé au réseau **192.168.11.0/24**. Cette segmentation logique permet d'isoler efficacement le trafic de la DMZ du reste du réseau, tout en conservant une architecture souple, évolutive et facilement administrable.

Le serveur Portail ERP est configuré avec une adresse IP fixe (**192.168.11.2**), ce qui facilite :

- la mise en place des règles de filtrage sur le pare-feu,
- les redirections de ports depuis Internet,
- le contrôle précis des flux autorisés.

Cette organisation améliore la lisibilité de l'infrastructure réseau et permet une gestion fine et maîtrisée des communications entre les différentes zones.

### Politique de filtrage et contrôle des flux

La politique de sécurité appliquée repose sur le principe du **moindre privilège**. Ce principe consiste à n'autoriser que les flux strictement nécessaires au fonctionnement des services, tout autre trafic étant bloqué par défaut. Les connexions en provenance d'Internet sont limitées aux seuls services exposés par le serveur ERP hébergé dans la DMZ. Les communications entre la DMZ et le réseau interne sont volontairement restreintes aux échanges indispensables au fonctionnement applicatif. Aucune connexion directe entre Internet et le réseau interne n'est autorisée.

**Tableau 3 – Synthèse des flux autorisés**

| Source      | Destination       | Type de flux                     | Autorisation |
|-------------|-------------------|----------------------------------|--------------|
| Internet    | Serveur ERP (DMZ) | Accès applicatif (ports définis) | Autorisé     |
| Internet    | LAN interne       | Tous                             | Interdit     |
| DMZ         | LAN interne       | Flux applicatifs nécessaires     | Restreint    |
| LAN interne | DMZ               | Administration / Supervision     | Autorisé     |

Ce contrôle strict des flux permet de limiter les risques de propagation d'une attaque, de réduire la surface d'exposition du système d'information et de garantir que chaque communication répond à un besoin fonctionnel clairement identifié.

### Choix d'une DMZ dédiée et minimaliste

Le choix a été fait de concevoir une DMZ volontairement **minimaliste**, hébergeant uniquement le serveur Portail ERP. Cette approche permet :

- de réduire significativement la surface d'attaque,
- de simplifier la gestion des règles de sécurité,
- d'améliorer la maintenabilité et la lisibilité de l'architecture.

La DMZ est ainsi considérée comme une zone fonctionnelle dédiée à un service précis, et non comme une extension du réseau interne. Cette conception s'inscrit pleinement dans les bonnes pratiques de sécurité des systèmes d'information, notamment celles recommandées par l'ANSSI, en matière de cloisonnement des zones de confiance et de défense en profondeur.

### Conclusion

La mise en place de la DMZ constitue un élément clé de l'architecture réseau du projet. Elle permet d'exposer le serveur Portail ERP de manière sécurisée, tout en protégeant efficacement le réseau interne contre les menaces externes.

Grâce à l'utilisation de pfSense comme pare-feu central, à la segmentation via un VLAN dédié et à une politique de filtrage rigoureuse fondée sur le principe du moindre privilège, l'architecture répond aux exigences de sécurité, de lisibilité et d'évolutivité attendues dans un environnement professionnel.

## SAUVEGARDE

Le plan de sauvegarde mis en place pour XANADU repose sur la règle de sécurité **3-2-1**, reconnue comme une bonne pratique de référence en cybersécurité et recommandée par l'ANSSI. L'objectif de ce plan est de garantir les exigences de **Continuité d'Activité (PCA)** et de **Reprise après Incident (PRA)**, tout en respectant les contraintes de **RTO** et de **RPO** définies par la Direction.

La sauvegarde constitue un pilier fondamental de la résilience du système d'information. Elle permet de faire face aux incidents matériels, aux erreurs humaines, ainsi qu'aux cyberattaques de type ransomware ou corruption logique des données.

### Objectifs de récupération : RTO et RPO

Les objectifs de récupération sont définis à partir des besoins métier :

- **RTO (Recovery Time Objective)** : durée maximale acceptable pour restaurer un service ou une donnée après un incident.
- **RPO (Recovery Point Objective)** : perte de données maximale acceptable, exprimée comme l'intervalle de temps entre la dernière sauvegarde valide et l'incident.

| Catégorie             | Exemples                                            | RTO   | RPO   |
|-----------------------|-----------------------------------------------------|-------|-------|
| Critiques             | Base de données ERP, données Direction / Juridiques | ≤ 4h  | ≤ 4h  |
| Moyennement critiques | Fichiers partagés                                   | ≤ 24h | ≤ 24h |
| Peu critiques         | Dossiers personnels centralisés                     | ≤ 24h | ≤ 24h |

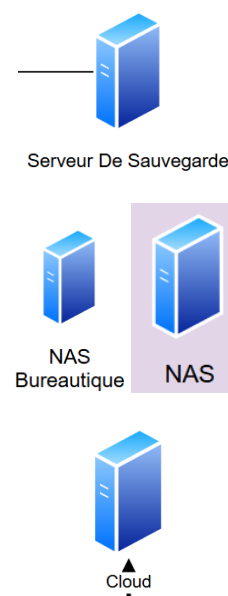
### Application de la règle 3-2-1

La règle **3-2-1** garantit une protection optimale des données :

#### Application de la règle 3-2-1

La règle **3-2-1** garantit une protection optimale des données :

- **3 copies des données** :
  - Serveur de production (salle des serveurs)
  - NAS interne
  - Stockage Cloud
- **2 supports de stockage différents** :
  - NAS (interne et externe)
  - Cloud
- **1 copie hors site** :
  - Cloud, conformément aux recommandations de l'ANSSI



Le Cloud permet de se prémunir contre les sinistres majeurs tels qu'un incendie, un vol ou une panne totale du site principal, tout en offrant des garanties de disponibilité via des SLA contractuels.

## Planification des sauvegardes

La planification des sauvegardes est définie selon la criticité des données :

| Données                          | Criticité            | Fréquence                                | Rétention                 | Archivage |
|----------------------------------|----------------------|------------------------------------------|---------------------------|-----------|
| ERP /<br>Dossiers<br>partagés    | Critiques            | Incr./Diff. 4h + complète<br>hebdo       | 14j NAS + 3<br>mois Cloud | 5 ans     |
| Données<br>partagées /<br>Emails | Importantes          | Incr. quotidiennes + com-<br>plète hebdo | 1 mois                    | 5 à 7 ans |
| Dossiers per-<br>sonnels         | Moins cri-<br>tiques | Incr. quotidiennes + com-<br>plète hebdo | 7 jours                   | –         |

La stratégie repose sur une combinaison de sauvegardes **complètes**, **différentielles** et **incrémentielles**. Les sauvegardes complètes sont réalisées hebdomadairement, de préférence le dimanche soir, afin de limiter l'impact sur l'activité en semaine. Les sauvegardes différentielles toutes les 4 heures pour les serveurs ADDS et les machines virtuelles ERP permettent de respecter un **RTO de 4 heures**. Les sauvegardes incrémentielles de la base de données ERP assurent quant à elles le respect du **RPO de 4 heures**, en capturant rapidement les transactions récentes sans surcharge du système.

La rétention est organisée sur plusieurs niveaux : une rétention courte sur NAS interne pour les restaurations rapides, une rétention longue via le Cloud pour répondre aux obligations légales, et une conservation hors ligne mensuelle garantissant une capacité de retour arrière étendue.

## PCA et PRA

Le **Plan de Reprise d'Activité (PRA)** vise à restaurer les services critiques sous un délai maximal de 4 heures, tandis que les services non critiques doivent être restaurés sous 24 heures. Les sauvegardes complètes hebdomadaires constituent la base de restauration, complétées par des sauvegardes incrémentielles et différentielles pour limiter la perte de données.

Le **Plan de Continuité d'Activité (PCA)** est renforcé par l'utilisation d'un Cloud souverain respectant des SLA contractuels, la priorisation des données critiques lors des restaurations, ainsi que par une architecture haute disponibilité (cluster de serveurs, stockage RAID 10).

La disponibilité de matériel de rechange (disques, switches, composants critiques) permet également de réduire significativement les temps d'indisponibilité.



## Solution logicielle recommandée : Veeam Backup & Replication

La solution **Veeam Backup & Replication** est recommandée pour la mise en œuvre de cette stratégie. Veeam repose sur des sauvegardes au niveau image (*Image-level Backup*), permettant la restauration complète d'une machine virtuelle, la restauration granulaire de fichiers ou d'objets applicatifs, ainsi que le démarrage instantané d'une VM (*Instant VM Recovery*).

La solution supporte nativement la règle 3-2-1, la réplication vers des NAS et le Cloud, et intègre des fonctionnalités avancées telles que **SureBackup** et le **Change Block Tracking (CBT)**, garantissant le respect des RPO critiques fixés par la Direction.

## AIR GAP (ZONE HORS LIGNE)

Une zone **Air Gap** est mise en place via un NAS externe isolé et non accessible en permanence depuis le réseau.



Cette approche constitue la dernière ligne de défense face aux attaques de type ransomware ou aux compromissions avancées.

Les caractéristiques de cette zone Air Gap sont les suivantes :

- Données sauvegardées hors ligne et hors portée d'une compromission réseau
- Conservation d'une sauvegarde complète mensuelle des données critiques
- Capacité de restauration fiable en cas d'infection persistante ou d'erreur humaine ancienne

Les sauvegardes stockées dans cette zone sont conservées pendant une durée d'un an, garantissant un point de restauration sûr, indépendant du réseau et du Cloud. L'Air Gap assure ainsi l'existence d'un point de reprise absolument fiable, même dans les scénarios d'attaque les plus graves, et renforce significativement la résilience globale du système d'information de XANADU.

# SURCÔÛS ENTRAÎNÉS

---

## Analyse des surcoûts et justification des choix techniques

Dans le cadre du projet XANADU, plusieurs choix techniques ont été réalisés au-delà des exigences minimales du cahier des charges initial. Ces choix engendrent des surcoûts financiers, volontairement assumés afin d'augmenter significativement le niveau de sécurité, de résilience et de pérennité du système d'information.

Les décisions prises s'appuient sur les recommandations de l'ANSSI, sur les bonnes pratiques observées en PME, ainsi que sur une estimation réaliste des coûts basée sur les tarifs publics des éditeurs de solutions professionnelles et sur des retours d'expérience du monde professionnel.

### Solution antivirus professionnelle centralisée

Le premier surcoût notable concerne la mise en place d'une solution antivirus professionnelle centralisée, en remplacement d'un antivirus natif ou grand public. Bien que Windows Defender intégré aux systèmes Windows offre une protection de base satisfaisante, il présente des limites importantes dans un environnement professionnel, notamment en matière de visibilité globale, de corrélation des incidents et de réponse centralisée.

Les solutions antivirus grand public ont été écartées, car elles ne sont pas conçues pour une intégration avec un Active Directory et ne permettent pas une administration homogène du parc informatique. Le choix d'une solution professionnelle centralisée, telle que Microsoft Defender for Endpoint ou une solution équivalente, permet une supervision globale des postes et serveurs, une détection comportementale avancée des ransomwares et une intégration native avec l'annuaire Active Directory.

Les coûts associés à ce type de solution sont estimés entre 5 et 8 euros par utilisateur et par mois. Pour une entreprise de 60 utilisateurs, cela représente un surcoût annuel compris entre **3 600 et 5 760 euros**, auquel s'ajoute un coût indirect lié à l'administration et à la supervision. Ce surcoût est justifié par le niveau de protection apporté et par les recommandations de l'ANSSI.

### Interconnexion WAN via une infrastructure cloud

Un second surcoût est lié à l'utilisation d'une infrastructure cloud comme point d'interconnexion WAN entre les sites d'Atlantis et de Springfield. Une solution MPLS privée aurait présenté un coût élevé (entre 300 et 600 euros par mois), une faible flexibilité et une dépendance forte à l'opérateur télécom.

À l'inverse, une interconnexion reposant uniquement sur Internet public aurait réduit les coûts, mais au détriment de la résilience et de la qualité de service. Le recours au cloud, associé à des tunnels VPN chiffrés, permet de bénéficier d'une haute disponibilité native, d'une grande flexibilité et d'un déploiement rapide.

Les coûts d'une passerelle VPN cloud sont estimés entre **50 et 150 euros par mois**, soit environ **600 à 1 800 euros par an**. Cette solution respecte les recommandations de l'ANSSI, sous réserve d'un chiffrage strict des flux.

### **Pare-feux de nouvelle génération**

La sécurisation périmétrique du système d'information repose sur l'utilisation de pare-feux de nouvelle génération (NGFW), engendrant un surcoût par rapport à un filtrage réseau basique. Les solutions minimales offrent une visibilité limitée et peu de capacités de détection.

Les NGFW permettent une inspection applicative des flux, une journalisation détaillée, la détection d'intrusions et une gestion centralisée des tunnels VPN. Les coûts estimés pour des équipements adaptés aux PME sont compris entre **1 500 et 3 000 euros à l'achat**, auxquels s'ajoutent des licences annuelles de sécurité estimées entre **500 et 1 000 euros par an**. Ce choix s'inscrit dans une logique de défense en profondeur recommandée par l'ANSSI.

### **Architecture VPN hybride**

La mise en place de plusieurs types de VPN constitue également un surcoût. Le VPN site-à-site entre Atlantis et Springfield garantit la confidentialité des échanges inter-sites, tandis que le VPN client-à-site sécurise les accès distants des utilisateurs en mobilité ou en télétravail.

Une solution unique aurait été moins coûteuse, mais moins adaptée aux usages. Le choix d'une architecture VPN hybride (IPsec et VPN client) entraîne un surcoût estimé entre **300 et 800 euros par an**, justifié par une meilleure séparation des flux et un niveau de sécurité renforcé.

### **Redondance de l'Active Directory**

La redondance de l'Active Directory constitue un autre surcoût significatif. Bien que non imposée par le cahier des charges, elle répond à la criticité de ce composant, souvent ciblé par les attaques.

La mise en place d'un contrôleur de domaine secondaire sur le site principal et d'un RODC sur le site distant engendre un surcoût lié aux ressources matérielles ou virtuelles. Ces coûts sont estimés entre **500 et 1 000 euros par serveur**, soit **1 000 à 2 000 euros** pour l'ensemble, hors coûts d'administration. Ce choix améliore significativement la résilience et la sécurité du SI, conformément aux recommandations de l'ANSSI.

### **Politique de sauvegarde renforcée**

La politique de sauvegarde mise en œuvre dépasse les exigences minimales en intégrant la règle du 3-2-1 et un stockage isolé de type *air gap*. Une solution plus simple aurait été moins coûteuse, mais vulnérable aux ransomwares.

Cette architecture implique l'acquisition d'un NAS professionnel, estimé entre **1 000 et 2 000 euros**, ainsi que des licences de sauvegarde professionnelles comprises entre **500 et 1 000 euros par an**. Ce surcoût garantit une capacité de reprise fiable en cas d'incident majeur.

## Conclusion

Les surcoûts observés dans le projet XANADU ne constituent pas des dépenses superflues, mais des investissements stratégiques visant à renforcer la sécurité, la disponibilité et la résilience du système d'information.

Sur la base des estimations présentées, le coût initial d'investissement (équipements et serveurs) est estimé entre **3 500 et 7 000 euros**. Les coûts récurrents annuels (licences, services cloud, sécurité et sauvegardes) sont quant à eux estimés entre **5 800 et 11 200 euros par an**.

Chaque choix technique a été réalisé après comparaison de plusieurs alternatives, en retenant la solution offrant le meilleur compromis entre coût, sécurité et exploitabilité, dans le respect des bonnes pratiques et des recommandations de l'ANSSI.

## CONCLUSION

---

Le projet XANADU avait pour objectif principal la modernisation, la sécurisation et la pérennisation du système d'information de l'entreprise dans un contexte de croissance et de multi-sites. À travers l'ouverture du site de Springfield et le déménagement vers la technopole Atlantis, il était essentiel de concevoir une architecture capable de répondre aux enjeux actuels de cybersécurité, de continuité d'activité et de mobilité des utilisateurs.

L'architecture proposée repose sur une segmentation réseau stricte par VLAN, une interconnexion sécurisée des sites via des tunnels VPN chiffrés, ainsi qu'une séparation claire des zones de confiance (LAN, DMZ, Air Gap). Cette approche permet de limiter la surface d'attaque, de réduire les déplacements latéraux en cas de compromission et de garantir une maîtrise fine des flux réseau, conformément aux principes de défense en profondeur recommandés par l'ANSSI.

La mise en œuvre de services critiques hautement disponibles, tels que l'Active Directory redondé, le RODC sur le site distant, la supervision centralisée via Zabbix et une politique de sauvegarde avancée basée sur la règle du 3-2-1, assure une forte résilience du système d'information. Ces choix techniques permettent de respecter les objectifs de PCA et PRA définis par la Direction, notamment un RTO de 4 heures pour les services critiques et une capacité de reprise fiable face aux incidents majeurs, y compris les attaques par ransomware.

La sécurité a été pensée comme un élément transversal de l'architecture : pare-feux de nouvelle génération, antivirus professionnel centralisé, DMZ dédiée au portail ERP, VPN hybrides et sauvegardes hors ligne constituent un ensemble cohérent visant à protéger les données, les utilisateurs et les services tout en conservant une flexibilité opérationnelle adaptée aux besoins métiers.

Ces choix impliquent des surcoûts maîtrisés, assumés comme des investissements stratégiques. Le coût initial d'investissement est estimé entre **3 500 et 7 000 euros**, tandis que les coûts récurrents annuels liés aux licences, aux services cloud, à la sécurité et aux sauvegardes sont évalués entre **5 800 et 11 200 euros par an**. Ces montants restent cohérents avec les pratiques observées en PME et sont justifiés par le niveau de sécurité, de disponibilité et de fiabilité obtenu.

En conclusion, l'architecture proposée pour XANADU constitue une solution robuste, évolutive et sécurisée, capable d'accompagner durablement l'entreprise dans son développement. Elle offre un équilibre pertinent entre contraintes budgétaires, exigences métiers et recommandations institutionnelles, tout en posant des bases solides pour l'évolution future du système d'information, notamment en cas d'ouverture de nouveaux sites ou d'intégration de nouveaux services.